

SOC HANDS-ON WORKSHOP

SESIÓN 02

Detección & MITRE ATT&CK

Mapea amenazas · Automatiza respuestas · Demuestra cobertura

CON INVITADO · sesión especial

02

Perspectiva del invitado

Un profesional en el campo comparte su experiencia real



INVITADO

Nombre · Rol · Empresa

¿Qué veremos hoy?

00:00

Recap S01 + bienvenida al invitado

MITRE, automation, contención — dónde quedamos

00:10

¿Qué es MITRE ATT&CK y por qué importa?

Framework, tácticas, técnicas — sin memorizar, sí entender

00:30

Ejercicio 03 · MITRE Coverage en Sentinel

Ver qué tácticas cubre el lab y cuáles quedan sin detección

01:00

Ejercicio 04 · Automation Rules

Crear una regla que asigna y clasifica incidentes automáticamente

01:30

Ejercicio 05 · Device Isolation cross-platform

CrowdStrike detecta → Sentinel orquesta → MDE aísla el endpoint

01:50

Cierre · Q&A con el invitado · preview S03

Reflexión, preguntas, link registro Sesión 03

Recap sesión anterior

- ✓ Lab desplegado en Azure
- ✓ KQL: primera query real
- ✓ Threat Intel con MDTI
- ✓ Incidente unificado en XDR
- ✓ 22 alertas correlacionadas

MITRE ATT&CK: el mapa del atacante

Un diccionario de cómo atacan los adversarios reales — basado en observaciones del mundo real

Táctica

El QUÉ

El objetivo del atacante.
Ejemplo: Initial Access,
Persistence, Exfiltration

Técnica

El CÓMO

El método específico.
Ejemplo: Spearphishing
Attachment (T1566.001)

Sub-técnica

El DETALLE

La variante específica.
Ejemplo: Link vs.
Attachment vs. Service

Las 10 tácticas cubiertas en el Training Lab

Initial Access

Execution

Persistence

Privilege Escalation

Defense Evasion

Credential Access

Discovery

Lateral Movement

Collection

Exfiltration

"La Pyramid of Pain muestra que los TTPs (en la cima) causan el máximo dolor al atacante cuando se detectan — son costosísimos de cambiar. Un IOC (en la base) se reemplaza en minutos. Mapear a MITRE es operar desde la cima."

MITRE ATT&CK Coverage del lab

Identifica brechas · mapea reglas · encuentra qué tácticas no están cubiertas

Objetivo

Navegar la matriz MITRE en Sentinel, identificar qué tácticas cubre el Training Lab con sus 22 reglas activas y entender cuáles quedan como gap — exactamente como lo haría un analista en su primer día.

Dónde lo harás

Defender portal
→ Microsoft Sentinel
→ Threat management
→ MITRE ATT&CK

Preguntas que responderás

- Q1** ¿Cuántas de las 14 tácticas MITRE están cubiertas? ¿Cuáles son los gaps?
- Q2** ¿Qué técnica específica detecta el credential dumping de CrowdStrike? ¿Cuál es su ID?
- Q3** ¿Puedes identificar una táctica que el atacante usó pero que ninguna regla detecta?

"Los TTPs están en la cima de la Pyramid of Pain: son costosísimos para el atacante cambiar. Cuando mapeas una alerta a MITRE T1078 (Valid Accounts), no solo estás clasificando — estás entendiendo qué tan difícil es para el adversario evadir esa detección."

Automation Rules: respuesta sin código

Orquestación centralizada de respuesta — sin necesidad de playbooks para casos simples



TRIGGERS

- ▶ Incidente creado
- ▶ Incidente actualizado
- ▶ Alerta creada



CONDITIONS

- ▶ Nombre de la regla
- ▶ Severidad del incidente
- ▶ Tácticas MITRE
- ▶ Propiedades de entidad



ACTIONS

- ▶ Asignar propietario
- ▶ Cambiar severidad
- ▶ Agregar tag
- ▶ Cerrar incidente
- ▶ Ejecutar playbook

Lo que debes saber para el ejercicio

Orden de ejecución: Las reglas se ejecutan secuencialmente — el número que asignas determina la prioridad

Fecha de expiración: Puedes crear reglas temporales (ideal para suprimir ruido durante mantenimientos)

Sin playbook: Para acciones simples (asignar, etiquetar, cerrar) no necesitas Logic Apps — la automation rule es suficiente

Automation Rules — respuesta automática

Clasificar · asignar · priorizar incidentes sin intervención manual

Objetivo

Crear una automation rule que detecte incidentes de alta severidad de Credential Access, los asigne automáticamente y les agregue el tag 'Priority-1' sin ninguna intervención manual.

Dónde lo harás

Defender portal
→ Microsoft Sentinel
→ Configuration
→ Automation

Configuración de la regla que crearás

Trigger: Cuando se crea un incidente

Condición 1: Severidad = Alta

Condición 2: Tácticas contiene 'Credential Access'

Acción 1: Asignar propietario → [tu usuario]

Acción 2: Agregar tag → Priority-1

Acción 3: Cambiar estado → Active

"La Pyramid of Pain en práctica: cuando una automation rule detecta Credential Access (T1003), está operando en el nivel de TTPs — no en el de IOCs. Esto significa que el atacante necesita cambiar su TTP completo para evadir la detección."

Device Isolation cross-platform

CrowdStrike detecta → Sentinel orquesta → MDE aísla el endpoint en segundos

Objetivo

Configurar una automation rule que, cuando CrowdStrike dispare sobre un endpoint comprometido, ejecute automáticamente el aislamiento del dispositivo en Microsoft Defender for Endpoint.

Prerequisito

Dispositivo onboarded en Microsoft Defender for Endpoint (MDE)

1

CrowdStrike

detecta malware en el endpoint

2

Sentinel

recibe alerta via custom table + regla

3

Automation Rule

evalúa condiciones y ejecuta acción

4

MDE Action

aisla el endpoint en segundos

Este es el único ejercicio del lab que requiere infraestructura real — el resto funciona 100% sobre datos simulados

SOC sin automation vs. SOC con Sentinel

Lo que cambia cuando automatizas la respuesta a incidentes

ASPECTO	SIN AUTOMATIZACIÓN	CON SENTINEL AUTOMATION
Tiempo de detección	Minutos a horas (depende del turno)	Segundos (regla activa en tiempo real)
Clasificación de incidentes	Manual — el analista revisa uno por uno	Automática por severidad, táctica, entidad
Contención de endpoint	Escalada → ticket → esperar acceso	Automation rule → MDE aísla en segundos
Cobertura de amenazas	Lo que el analista recuerda revisar	Mapeado a MITRE ATT&CK — visible en matriz
Turno de madrugada	Analista fatigado, alertas sin respuesta	Reglas activas 24/7 sin intervención humana

Atribuir es más difícil de lo que parece y más valioso

El proceso de atribución y el Diamond Model aplicado a detecciones reales

Las 4 categorías de threat actors — y qué significa para tus reglas de Sentinel

Hacktivism

Motivación ideológica. Ataques de visibilidad. No buscan persistencia larga.
→ Reglas de detección simples y reactivas son suficientes.

Cybercrime

Motivación económica. Ransomware, credential theft. Los más comunes en banca LATAM. → Prioriza detecciones de Credential Access y Exfiltration.

Cyber Espionage

Nation-state o competidores. APTs con baja huella y exfiltración selectiva. → Requiere Data Lake para hunting retroactivo (lo que veremos en S04).

? Unknown

Cuando la evidencia no permite clasificar. Asumir incorrectamente es peor que no atribuir. → Deja el campo 'Classification' en blanco hasta tener evidencia.

¿Qué lograste hoy?

SESIÓN 02 completada



MITRE mapeado

Identificaste gaps reales de cobertura en tu workspace



Automation activa

Regla que clasifica y asigna incidentes automáticamente



Contención cross-platform

CrowdStrike → Sentinel → MDE: segundos no horas



Perspectiva de campo

Un profesional compartió cómo opera Sentinel en el mundo real

Próxima sesión → S03: Detection Engineering

Ajustarás reglas para eliminar falsos positivos y construirás detecciones enriquecidas con watchlists sobre comportamiento anómalo de identidad

Registro → meetup.com/msperu/events/314627423